Document 17 — Data Protection Impact Assessment: Identity Verification (Didit)

Controller	[COMPANY NAME], trading as PlayStake
Owner	[COMPLIANCE LEAD NAME], Head of Compliance; [DPO OR PRIVACY LEAD]
Version	0.1 — first draft for review
Review	Before switching Didit from sandbox to live; then annually, and on any change to the workflow, provider or data held
Relates to	UK GDPR Articles 6, 9, 28, 35 and 44–49; Data Protection Act 2018 Schedule 1; Gambling Commission LCCP social responsibility code 3.2 (age verification) and customer due diligence; Money Laundering Regulations 2017 (as they apply to PlayStake — to be confirmed); Documents 06, 07, 08, 13

> First draft prepared on 22 October 2026 from the integration as built. `[BRACKETS]` and the questions in section 8 must be answered, ideally with legal or data-protection advice, before Didit is used for real customers. A DPIA is required here because the processing uses biometric data to identify people and is carried out at scale on everyone who wants to gamble.

1. What the processing is

Before a customer can deposit, use free-to-play features or gamble, PlayStake must verify their identity, age and address, and screen them for financial-crime risk (Document 06, Document 07). PlayStake uses Didit's hosted verification:

1. The customer starts the check from **Verify ID**. PlayStake creates a Didit session, passing only the customer's PlayStake user id, email and the date of birth they declared at sign-up.
2. On Didit's page the customer photographs their identity document, takes a selfie, and uploads a proof of address.
3. Didit checks the document for authenticity and tampering, runs a passive liveness check, matches the selfie to the document photo, reads the date of birth and declines anyone under 18, checks the proof of address, and screens the customer against sanctions, PEP and adverse-media lists (with ongoing re-screening).
4. PlayStake receives a signed notification, re-reads the decision from Didit's API, and stores: name, date of birth, address, document type and issuing country, Didit's status, scores and reasons. **Images are not copied to PlayStake.**
5. PlayStake then runs its own checks (date of birth against sign-up, same identity on another account, GAMSTOP) and either verifies the customer, rejects with reasons, or sends the case to staff.

A manual upload route remains as a fallback; those documents are stored encrypted by PlayStake (Document 06 §3.2).

2. Data, people and volumes

Item	Detail
Data subjects	Adults (and anyone attempting to sign up, including under-18s who must be refused) who want to gamble on PlayStake, mainly UK residents
Personal data	Name, date of birth, address, email, document type, number and expiry (held by Didit), proof-of-address document, IP and device data collected by Didit
Special category data	Facial biometric data (selfie and face template) used to confirm the person matches the document — Article 9
Criminal-offence-type data	Possible: adverse-media and sanctions hits can relate to alleged offences — Article 10
Volume	Beta: under 500 a month. At launch: [ESTIMATE]
Retention	Didit: [PERIOD SET IN DIDIT — align with the AML retention period, normally 5 years after the relationship ends]. PlayStake: verification record for the same period (Privacy Policy)

3. Lawful basis

Purpose	Article 6 basis	Article 9 / 10 condition
Age verification (keep under-18s out)	Legal obligation — Gambling Act 2005 and licence conditions	DPA 2018 Sch 1 Part 2: **preventing or detecting unlawful acts** (para 10) and **regulatory requirements** (para 12); [CONFIRM WITH ADVICE]
Identity and address verification, one-person-one-account	Legal obligation (licence conditions, customer due diligence)	As above
AML screening and ongoing monitoring	Legal obligation	Sch 1 para 10 / 12; Article 10 via Sch 1 Part 3 [CONFIRM]
Fraud prevention (document forgery, liveness attacks)	Legitimate interests and legal obligation	Sch 1 para 10 / 14 (preventing fraud) [CONFIRM]

PlayStake needs an **appropriate policy document** under DPA 2018 Sch 1 Part 4 for these conditions: [TO DRAFT — can be an annex to this document].

Consent is **not** relied on: verification is a condition of gambling and the customer has no real choice. The alternative for customers who can't or won't use biometrics is the manual upload route, which still involves a selfie checked by a person — [DECIDE whether to offer a non-biometric route, e.g. electoral-roll check plus document, and record the decision here].

4. Necessity and proportionality

- **Necessary:** the Gambling Commission requires age and identity to be verified before gambling; a document plus liveness and face match is the standard way to show the person is real and is the document holder, which also stops under-18s using a parent's ID.

- **Minimised:** PlayStake keeps only what it needs to show the check was done and to run its own controls; images stay with Didit. Didit is not asked for data PlayStake doesn't use (database lookups and proof-of-funds are off).
- **Accurate:** borderline results go to a person; the customer is told the reasons for a decline and can try again; staff can correct a record.
- **Transparent:** the Privacy Policy names Didit, explains the selfie is biometric, and lists what PlayStake receives; the Verify ID page says what is needed and links to the Privacy Policy.
- **Rights:** access, rectification and erasure requests are handled under the Privacy Policy; erasure is limited while the AML retention period runs.

5. Risks and controls

Risk to individuals	Likelihood / severity	Controls	Residual
Biometric or document data breached at the provider	Low / high	Didit ISO 27001 and SOC 2 Type II; DPA with security terms; images never copied to PlayStake; access to Didit's console limited to named staff with two-factor	Low
Breach at PlayStake	Low / medium	Only text results stored; database access controlled (Document 13); webhook signatures and timestamps verified; decisions re-read from Didit's API	Low
Wrongly declined (e.g. poor photo, unusual document) and locked out of the service	Medium / medium	Reasons shown; retry allowed; borderline results reviewed by a person; manual upload fallback	Low
Under-18 approved	Low / high	Didit age rule (18+, decline) on every accepted country; PlayStake re-checks age from the document before any automatic approval; under-18 closure process (Document 06)	Low
Bias in face matching or liveness for some groups	Unknown / medium	iBeta liveness certification; borderline matches go to a person; [ASK DIDIT for accuracy figures by demographic]	To assess
Excessive retention	Medium / medium	Retention set in Didit to the AML period; deletion on expiry [CONFIRM Didit deletes automatically]	Low once set
International transfer outside the UK	Possible / medium	Didit is in the EU (adequacy regulations apply); [CONFIRM all sub-processors and locations; IDTA or addendum for any outside UK/EU adequacy]	To confirm
AML false positive treated as fact	Medium / medium	AML hits never auto-decline; staff review every possible match and record the outcome (Document 07)	Low

6. Measures agreed

1. Sign Didit's DPA (Article 28) and record it in the supplier register (Document 08).
2. Set Didit's retention to [PERIOD] and confirm automatic deletion.
3. Restrict Didit console access to named staff, with two-factor sign-in.

4. Keep the manual upload route, and decide on a non-biometric alternative (section 3).
5. Review a monthly sample of automatic approvals against Didit's evidence (Document 06 §8).
6. Re-assess this DPIA before going live and when the workflow changes.

7. Sign-off

Role	Name	Decision	Date
Head of Compliance	[NAME]	[APPROVE / CHANGES]	
DPO or privacy lead	[NAME]	[ADVICE]	
Board / MLRO	[NAME]		

If residual high risk remains that cannot be reduced, consult the ICO before processing (Article 36).

8. Questions to put to Didit

1. Where are document images, selfies and face templates processed and stored? List all sub-processors and countries.
2. Is any biometric template kept after the session, for example for duplicate detection across Didit customers?
3. What retention options are there, and is deletion automatic and evidenced?
4. Accuracy and bias: false-accept and false-reject rates for liveness and face match, by age, sex and skin tone.
5. Breach notification timescales and process.
6. UK certification (UK digital verification services trust framework), or independent accuracy testing for UK documents.

Version history

Version	Date	Change
0.1	22 October 2026	First draft from the Didit integration as built